

AI GOVERNANCE FRAMEWORK

A Dual-Framework Case Study: NIST AI RMF & EU Market Abuse Regulation (MAR)
Applied to AI-Based Market Surveillance

Prepared by Amisha Gupta

DevOps Engineer | Associate Scrum Master | AI Governance Practitioner (in progress)
August 2026

Disclaimer

This is an independent governance case study prepared for professional portfolio purposes. It is based entirely on publicly available product documentation and regulatory materials referenced at the end of this document, including Nasdaq's public Market Surveillance factsheet and its published summary of the EU Market Abuse Regulation (MAR). The author has no affiliation with, insider knowledge of, or proprietary access to Nasdaq or any exchange's internal systems. All analysis, risk classifications, and governance recommendations represent the author's independent application of recognised frameworks to publicly documented system types, for the purpose of demonstrating AI governance methodology.

Contents

1. System Overview
2. Risk Classification — NIST AI RMF
3. Regulatory Basis — EU Market Abuse Regulation (MAR)
4. Governance Controls
5. Data & Privacy
6. Monitoring & Audit
7. Incident Response
8. About This Case Study & Author

1. System Overview

This case study examines Nasdaq Market Surveillance, a real-time AI-based market surveillance platform used by over 50 exchanges and 170+ banks and brokers globally, including regulators such as IIROC in Canada, which relies on the system to monitor over one billion transactions daily across Canadian debt and equity markets.

The platform covers the full surveillance lifecycle — real-time monitoring and alerting, case management, investigation, and regulatory reporting — across asset classes including equities, derivatives, fixed income, FX, commodities, and digital assets. It applies machine learning to detect anomalies and prioritise risk using a behavioural, risk-based approach, with the stated aim of reducing false positives by analysing complete, cross-referenced datasets rather than isolated signals.

Two capabilities are particularly relevant from a governance perspective. First, an Investigation Canvas surfaces AI-generated “Evidence Cards” that summarise relevant context — internal data, historical behaviour, and external references — in natural language, supporting human analyst decision-making rather than replacing it. Second, a “Replay” capability allows investigators to reconstruct the full historical order book for any given timeframe, providing an auditable, granular record for confirming or dismissing a flagged case.

When the system flags suspicious activity, human surveillance analysts investigate and confirm before any regulatory action is taken — a human-in-the-loop design that is central to how this governance framework classifies and manages the system's risk.

Why this system

Market surveillance AI sits at the intersection of high financial stakes, individual privacy exposure, and direct regulatory accountability — and, unusually, is governed by a well-documented regulatory regime (MAR) that predates most AI-specific regulation. This makes it an unusually well-grounded case study for demonstrating how AI governance principles apply in a mature, already-regulated domain.

2. Risk Classification — NIST AI RMF

Under the NIST AI Risk Management Framework, AI systems are governed through four interconnected functions: Govern, Map, Measure, and Manage. Govern sits across the whole framework as the cross-cutting organisational foundation — policies, accountability, culture, and oversight that make the other three functions possible.

Risk Tier Assigned: High-Risk AI System

Justification: This system directly influences regulatory investigations against real individuals and firms. A false positive can trigger costly investigations and reputational harm to innocent traders; a false negative can allow real market manipulation to go undetected, undermining market integrity itself. Security, reliability, explainability, and privacy concerns all apply directly to a system of this type.

NIST Function	Applied to Nasdaq-type Market Surveillance System
Govern	Ownership sits jointly with Compliance and Technology functions, with escalation to a Chief Risk Officer for confirmed manipulation cases. Policies define who may approve alert-logic or model changes before deployment.
Map	System touches trading data (commercially sensitive), individual trader identity (privacy-relevant), and regulatory reporting obligations across 12+ asset classes. Third-party data such as news sentiment feeds is mapped as a dependency risk.
Measure	Detection accuracy, false positive rate, and false negative rate are tracked

NIST Function	Applied to Nasdaq-type Market Surveillance System
	continuously against defined benchmarks, alongside model drift as trading patterns evolve over time.
Manage	Defined incident response protocols exist for wrongful flags and missed detections, including model retraining cadence and mandatory human override procedures via analyst investigation.

3. Regulatory Basis — EU Market Abuse Regulation (MAR)

Unlike many emerging AI use cases, AI-based market surveillance operates within an already mature regulatory regime. The EU's Market Abuse Regulation (MAR) predates most AI-specific governance frameworks and provides a non-exhaustive list of manipulation “indicators” in its Annex 1 — patterns that surveillance systems, human or automated, are expected to detect. This gives the AI governance function a second, domain-specific framework to govern against, alongside NIST.

MAR explicitly acknowledges that its list of indicators is non-exhaustive: a surveillance function cannot consider itself compliant merely by covering the named scenarios, and must continuously evaluate whether its monitoring captures manipulative devices beyond the documented examples. This has a direct AI governance implication — it means model coverage and alert logic require periodic independent review, not a one-time compliance checklist.

MAR Annex 1 Indicator (selected)	Illustrative Alert Coverage Mapped to It
A(A) — Orders/transactions representing a significant, price-moving share of daily volume	Quote stuffing, wash sales, multi-party collusion, marking the close, unusual price movement intra-day
A(C) — Transactions with no change in beneficial ownership	Wash trades, matched orders, prearranged trading, parking
A(F) — Orders that shift the best bid/offer and are withdrawn before execution	Spoofing, layering, bait-and-switch, order withdrawal, unusually large bid-ask spread
B(A) — Trading preceded or followed by dissemination of false or misleading information	Insider trading — price change, insider dealing participant profile, insider watch list
Governance implication MAR also requires firms to retain records of telephone conversations, electronic communications, and other data traffic as evidence of intent — since intent, not just executed trades, falls within scope. This creates a direct tension with data minimisation principles common in AI/privacy governance, and is addressed explicitly in Section 5.	

4. Governance Controls

Ownership & Accountability

- System owner: joint Compliance + Technology governance board
- Model and alert-logic changes require sign-off from both regulatory compliance and engineering leads before deployment — mirroring standard change control processes used in regulated CI/CD environments

- A cross-functional governance team spanning data & analytics, technology, business, risk, and people functions is required to operationalise a framework of this kind successfully

Access Control

- Least-privilege access enforced on model parameters, alert configuration, and training data repositories
- Full audit logging for every model or alert-logic configuration change, consistent with audit trail practices already standard in regulated production environments

Change Management

- Any AI-recommended alert parameter optimisation requires explainability review and validation before going live — no silent model updates in production
- Test cases validate model behaviour changes post-deployment, the same discipline applied to software pipeline changes
- Given MAR's non-exhaustive indicator list, alert coverage is reviewed on a fixed periodic cycle, not treated as a static, one-time compliance exercise

5. Data & Privacy

- Training data includes historical trading records and past alert dispositions (human-labelled “true fraud” vs. “false alarm” cases)
- Individual trader data is privacy-sensitive — even traders who are flagged and later cleared carry residual privacy exposure if investigation records are not properly access-restricted
- MAR requires retention of communications data (calls, electronic messages, data traffic) as evidence of manipulative intent — meaning a data minimisation policy cannot simply delete this data early; retention periods must be defined against MAR's evidentiary requirements, with access strictly limited to authorised investigators
- A data retention policy is required: how long are false-positive investigation records retained, and who is authorised to access them
- Third-party and cross-asset data — spanning equities, derivatives, and in some deployments cryptocurrency and digital assets — introduces varying regulatory regimes that data governance policy must account for

6. Monitoring & Audit

- Ongoing human feedback loops are essential, not optional — models are most effective when continuously trained on live surveillance team dispositions rather than static historical data alone
- Recommended cadence: quarterly model performance reviews measuring false positive and false negative rate trends
- Because MAR's Annex 1 indicators are explicitly non-exhaustive, monitoring must also test for novel manipulation patterns beyond the documented scenario list — not just accuracy against known fraud types
- Root cause analysis is conducted for every wrongful flag, applying the same RCA discipline used for production incident management

7. Incident Response

Playbook A — False Positive Escalation

- An innocent trader is flagged and investigated in error

- Requires a defined remediation path, formal record correction, and a clear communication protocol to the affected party

Playbook B — Missed Detection

- Real market manipulation goes undetected by the system
- Requires root cause analysis on why the model missed the pattern — including whether it fell outside MAR's documented indicators — followed by a defined retraining or parameter-tuning response

Both playbooks apply the same root-cause-analysis and audit-trail discipline used for production pipeline incident response — simply applied to model behaviour rather than deployment failures.

8. About This Case Study & Author

This framework was independently developed by Amisha Gupta as part of a structured transition from DevOps Engineering and Scrum Mastery into AI Governance and Responsible AI practice. It applies two complementary frameworks — the NIST AI Risk Management Framework (Govern, Map, Measure, Manage) and the EU Market Abuse Regulation (MAR) — to a real, publicly documented AI system category: market surveillance technology. The dual-framework approach reflects how AI governance in regulated industries typically works in practice: general-purpose AI risk frameworks applied alongside sector-specific regulation, not in place of it.

The author brings 6 years of experience in regulated financial and healthcare environments, including CI/CD pipeline governance, access control, audit trail management, and Agile delivery — the same operational disciplines reflected in the governance controls proposed throughout this document.

Sources referenced: Nasdaq Market Surveillance public product factsheet ([nasdaq.com](https://www.nasdaq.com)); Nasdaq “Market Surveillance & Market Abuse Regulation” guide ([nasdaq.com/solutions/nasdaq-market-surveillance](https://www.nasdaq.com/solutions/nasdaq-market-surveillance)); Regulation (EU) No 596/2014 (Market Abuse Regulation); NIST AI Risk Management Framework (AI RMF 1.0, NIST AI 100-1); ESMA Review Findings, September 2020.